

SUPPORT ÉTUDIANT

Paielements Digitaux et Wallets numériques

Jour 3 : Tokenisation



Chrisvene MPANDZOU

chrisvene.mpandzou@a2mtech.com

M2 SIB · 2026 – 2027

Définition

DÉFINITION MONÉTIQUE

Qu'est-ce que la tokenisation ?

Substitution du **PAN** par un **token** utilisable dans un **domaine d'usage** défini, gouverné par une infrastructure dédiée (vault / TSP), afin de **réduire l'exposition** des données carte sans changer la logique monétique **Auth** → **Clearing** → **Settlement**.

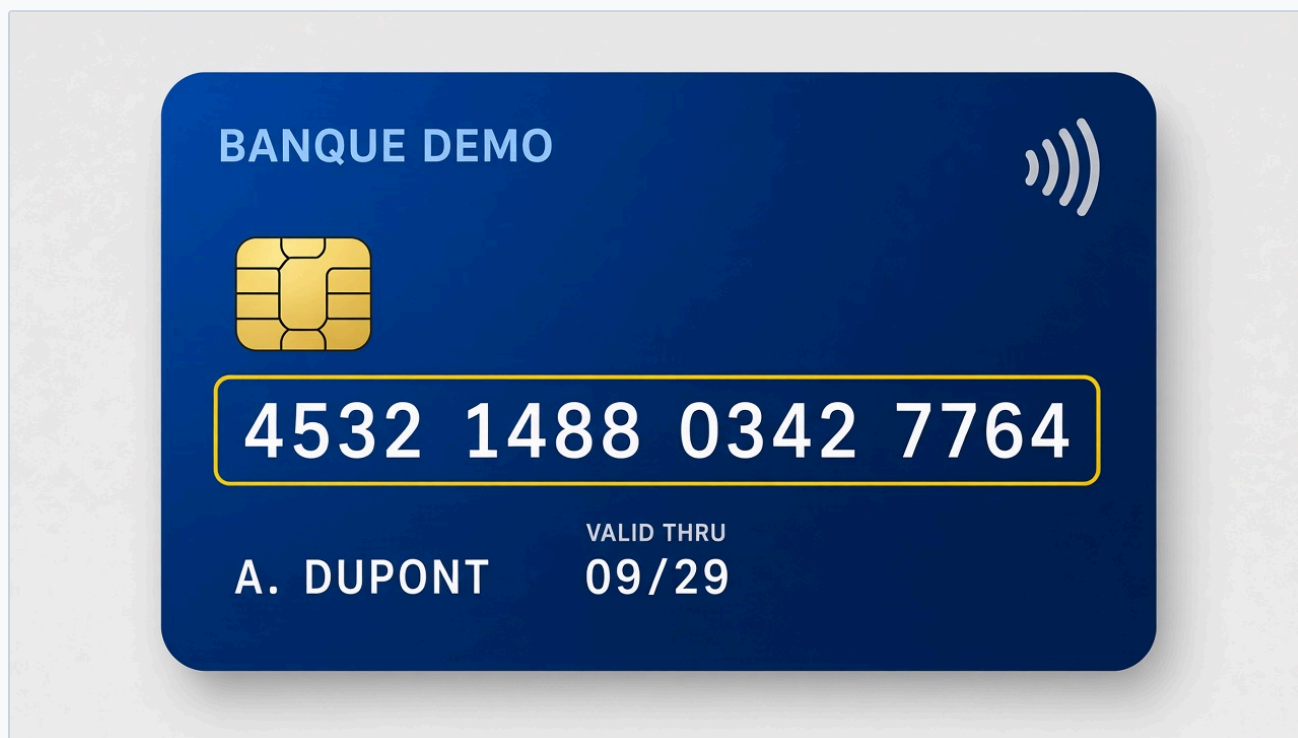
On sécurise l'identifiant présenté — pas le rail de paiement.

PAN et token – à définir

Deux numéros qui se ressemblent souvent à l'œil — ce n'est pas la même chose.

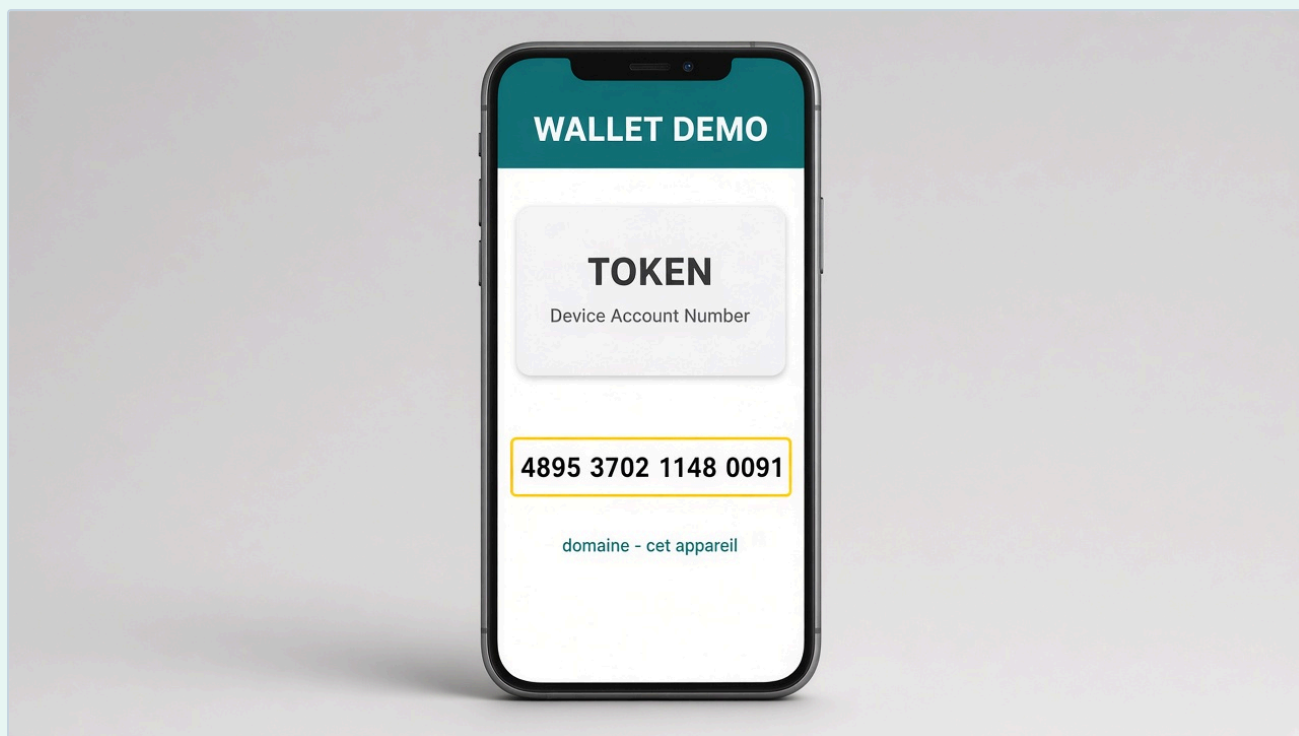
CARTE PLASTIQUE

PAN



PAN — *Primary Account Number* : numéro de compte carte (souvent 16 chiffres), imprimé ou embossé. Identifiant d'origine, **sensible**.

4532 1488 0342 7764



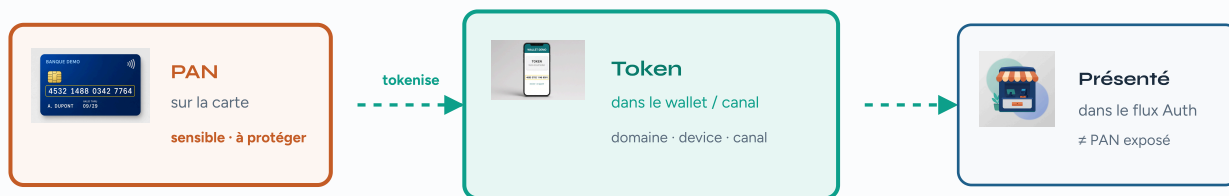
Token : substitut du PAN, émis pour un **domaine** (device, canal, marchand). Souvent même format — ce n'est *pas* le numéro de la carte.

4895 3702 1148 0091

Exemples pédagogiques uniquement. Le PAN reste la racine chez l'émetteur / le vault ; le canal (POS, app) voit le token.

TERME	DÉFINITION	OÙ ÇA VIT
PAN	Numéro de compte carte (sensible)	Issuer · vault / TSP
Token	Substitut du PAN pour un domaine	Device · canal · marchand (selon domaine)
Vault	Stockage sécurisé du mapping	Chez le TSP (souvent)
TSP	Token Service Provider — émet / gouverne	Scheme / réseau ou prestataire

Substitution illustrée



Le PAN reste la racine — le token est ce que le canal voit

VOCABULAIRE

Vault & TSP

Deux briques à ne pas confondre : le **vault** stocke le lien ; le **TSP** gouverne le cycle de vie.

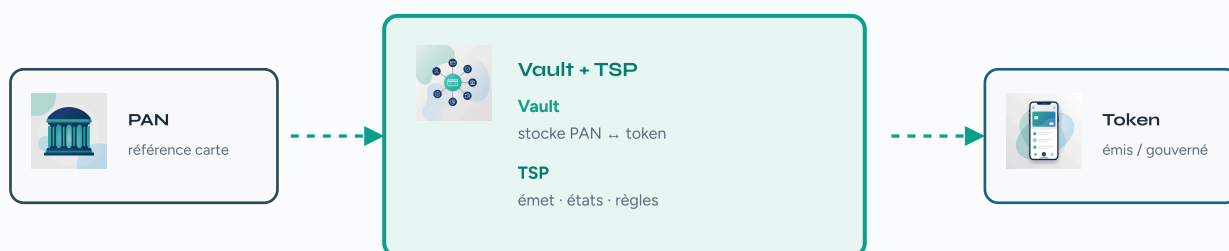
Token vault

- Référentiel sécurisé PAN ↔ token
- Où vit la correspondance (pas le canal)
- « Coffre » du mapping — pas l'acteur métier

TSP

- Token Service Provider
- Émet, active, suspend, supprime
- Applique règles de domaine / device
- Souvent scheme, parfois issuer ou acteur dédié

Lien PAN ↔ token



Vault = où vit le lien · TSP = qui gouverne le token

Où dans la chaîne ?

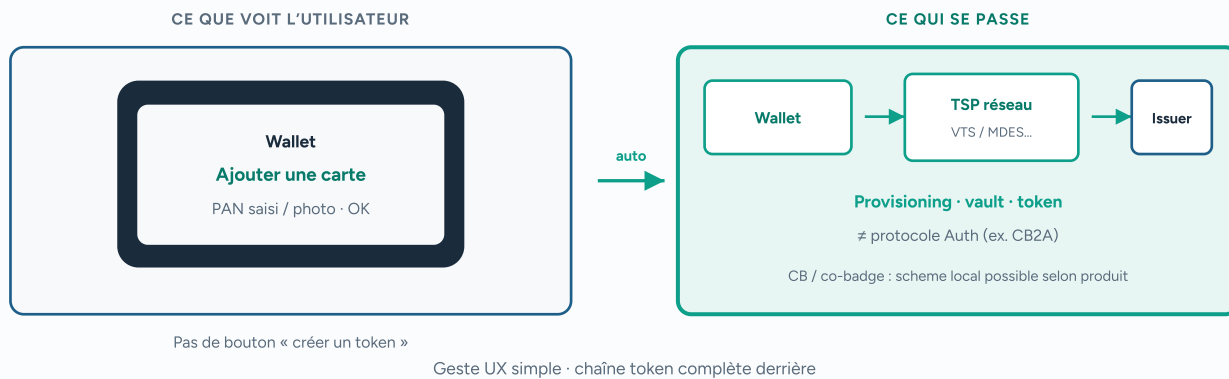
- Vault / TSP : côté **réseau / scheme** (souvent) — pas dans la caisse ni l'app marchande
- L'émetteur garde le PAN et la décision AuthZ — le TSP ne le remplace pas

Chaîne SI détaillée : [Architecture SI](#) · Qui voit token / PAN en Auth : [Lifecycle](#) · [Auth](#)

Comment naît le token (côté UX)

Le token est émis par un **TSP** après enrolment — pas « calibré » localement. Le flux technique complet est dans [Lifecycle · Provisioning](#) ; ici, l'angle Définition : ce que voit l'utilisateur vs la coulisse.

Côté UX — enrolment implicite



CLARIFICATION

À ne pas confondre

Tronquer et masquer se ressemblent à l'œil — ce n'est pas la même opération. Et aucun des deux n'est un token.

PAN tronqué · PAN masqué · Token

PAN tronqué

.... 7764

Conservation / stockage
on ne garde qu'un fragment
PAN complet non reconstituable

≠ token

PAN masqué

4532 7764

Affichage (écran, ticket, log)
le PAN complet peut encore
exister en base / vault métier

≠ token

Token

4895 3702 1148 0091

Substitut gouverné (TSP)
autre numéro · domaine
lien PAN dans le vault

≠ affichage du PAN

≠ **Chiffrement simple** Un token n'est pas un PAN chiffré affiché autrement : il a un domaine et une gouvernance.

≠ **Nouveau rail** Auth → Clearing → Settlement reste intact. On change l'identifiant exposé, pas la logique monétique.

≠ **Risque zéro** Exposition réduite — fraude, device et conformité restent des sujets SI.

Suite : [Pourquoi tokeniser](#) · [Domaines d'usage](#) · [Lifecycle](#) · [Provisioning](#).

Objectifs de la tokenisation

RÔLE

Pourquoi tokeniser

On ne change pas le rail **Auth** → **Clearing** → **Settlement** : on change *ce qui est présenté* — pour réduire l'exposition, la fraude réutilisable et le scope PCI.

TROIS RAISONS

Ce que la tokenisation vise

1 • Moins d'exposition du PAN

- Le canal voit un substitut, pas le numéro de carte
- Le PAN reste chez l'émetteur / vault / TSP
- Moins de copies dans POS, apps, logs, bases marchandes

2 • Fraude plus difficile à réutiliser

- Token souvent lié à un domaine (device, canal, marchand)
- Suspendre un token ≠ bloquer toute la carte
- Ex. : téléphone perdu → revoke ciblé

3 • Conformité (PCI-DSS)

- Moins de PAN côté marchand → scope PCI réduit — détail réglementaire : [Sécurité & conformité](#)

CONTEXTE

Pourquoi surtout en digital ?

Le rail carte classique expose peu de copies persistantes ; les canaux digitaux multiplient stockage et acteurs.

Rail classique vs canaux digitaux

Rail classique

Carte plastique → POS → Auth

- PAN lit / chip / bande — geste court
- Peu de stockage durable chez le marchand
- Exposition limitée dans le temps

Token utile, pas toujours central

Canaux digitaux

Wallet · e-com · in-app · card-on-file

- PAN entrerait dans apps, serveurs, cloud
- Stockage récurrent · multi-acteurs
- Surface d'attaque & scope PCI plus larges

Token = modèle par défaut

Réduit · conserve · déplace

EFFET	
Réduit	Copies du PAN dans POS, apps, logs, bases marchandes
Conserve	Rail Auth → Clearing → Settlement (J1) · décision chez l’issuer
Déplace	Gouvernance du mapping vers vault / TSP · responsabilité concentrée

Scope PCI réduit côté marchand ≠ disparition des contrôles (détail : 3.4).

Domaines d'usage

MODES / DOMAINES

Où on tokenise

Un token n'est pas universel : il est émis pour un **domaine** (canal, device, parfois marchand). Même rail
Auth → Clearing → Settlement — ce qui change, c'est *qui tokenise, où vit le token et ce qui circule*.

VUE D'ENSEMBLE

Trois terrains

In-store • In-app • E-commerce



In-store

proximité • wallet / NFC / POS



In-app

checkout natif dans l'app



E-commerce

web • COF • récurrent

E-commerce — card-on-file • récurrent

Geste	Saisie ou « enregistrer ma carte » au checkout web (1ère fois)
Qui tokenise	PSP / acquéreur / TSP card-on-file — PAN capturé en hosted fields / iframe
Où vit le token	Base marchand ou vault PSP — le PAN reste chez TSP / émetteur
Ce qui circule	Token via gateway • COF puis MIT (merchant-initiated) pour les abos
Contrainte SI	Scope PCI réduit • conformité COF/MIT • 3DS au 1er paiement • pas de PAN en DB
Exemples	Streaming • SaaS • marketplace 1-clic • renouvellement carte géré par le TSP

Cœur de la réduction PCI côté marchand

IN-STORE

Tap au POS

Le payeur ne tape pas son PAN : le device présente un token lié à l'appareil.

Domaine device → POS → Auth



Au moment du tap

Le device présente token + cryptogramme contactless — le TPE lance l'Auth EMV.

Le marchand / POS voit un identifiant tokenisé (souvent DPAN), pas le PAN d'origine.

Contrainte SI : terminal contactless certifié · schéma / wallet compatibles · pas de PAN en caisse.

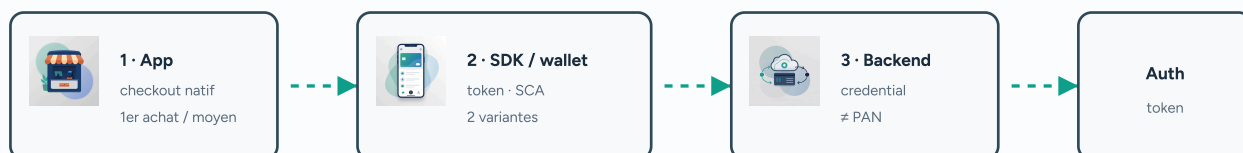
Pont J4 : même logique « le device présente, pas le PAN » · NFC / tags.

IN-APP

Checkout natif

L'achat se fait dans l'application du marchand — token wallet ou vault PSP, pas une WebView.

App → SDK / wallet → Backend → Auth



Côté SI marchand

Le backend reçoit une credential / payment token — jamais le PAN en clair.

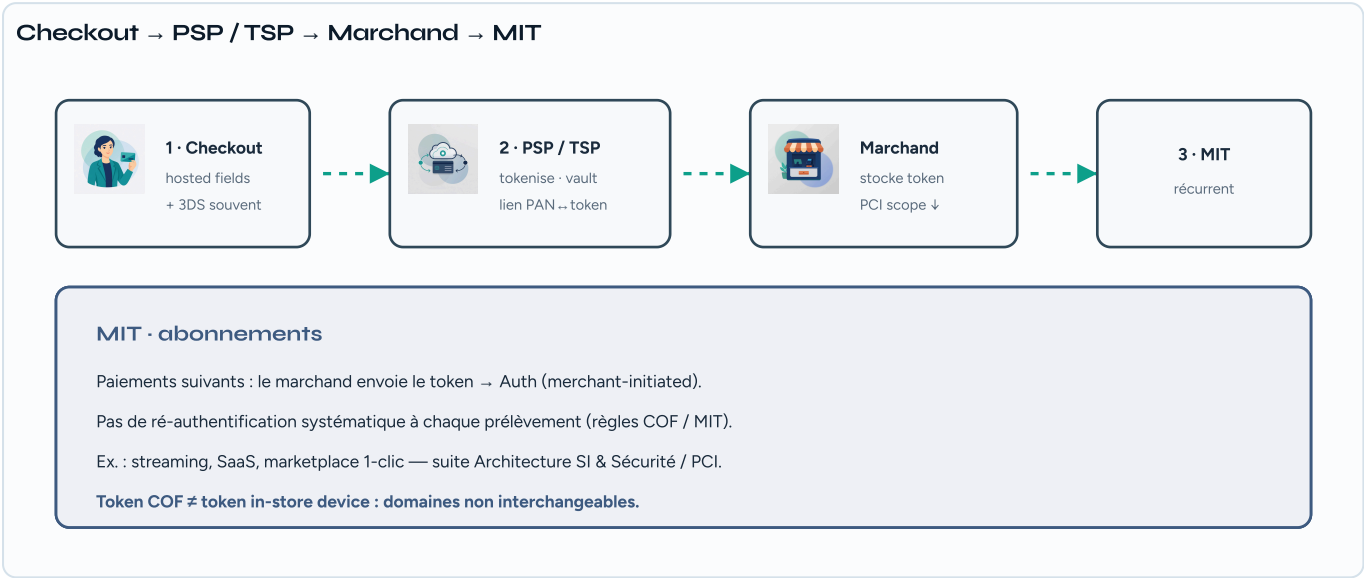
Contrainte : intégration SDK, gestion SCA/3DS, logs et base SANS PAN.

Révocation : supprimer la carte dans l'app ou revoke wallet — le marchand n'a souvent qu'un id.

Le rail Auth reste le même — seul le payload présenté change.

Card-on-file

Le marchand réutilise la carte (1-clic, abonnement) en stockant un token — pas le PAN.



SYNTHÈSE

Trois terrains · qui tokenise

	IN-STORE	IN-APP	E-COMMERCE / COF
Qui tokenise	TSP réseau (VTS · MDES · wallet OEM)	TSP / wallet OEM	PSP / TSP card-on-file
Où vit le mapping	Vault TSP / scheme	Vault TSP · device	Vault PSP / TSP
En Auth circule	TOKEN (+ crypto) jusqu'à l'acquéreur	TOKEN (+ crypto)	TOKEN marchand / PSP (souvent)
Risque type	Device perdu · clone NFC	Compte app compromis	Fuite base COF · MIT abusif

Question salle

Où reste le PAN — et quel domaine ?

- Vault / TSP / issuer — pas chez le marchand ni au POS
- Token in-store (device) ≠ token COF e-commerce
- Même rail J1 — contexte d'émission différent

Tokenisation réseau & cycle de vie

DÉFINITION MONÉTIQUE

Qu'est-ce que le lifecycle du token ?

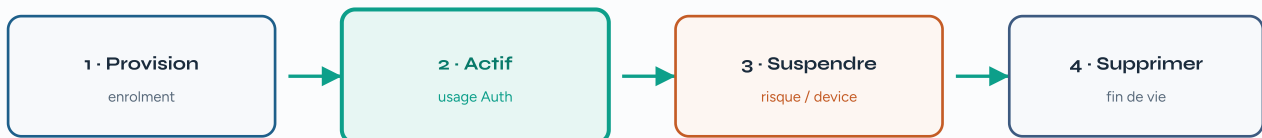
Ensemble des états et transitions d'un token : **provisioning** → **actif** (usage Auth) → **suspendre / reprendre** → **supprimer**. Distinct du cycle de la carte source : on gouverne un device / canal sans résilier le PAN. Durée = *états*, pas un TTL type OTP.

PARCOURS

Une seule carte du cycle

Quatre temps — détaillés ensuite : provisioning, stockage, Auth, gouvernance.

Provision · Actif · Suspendre · Supprimer

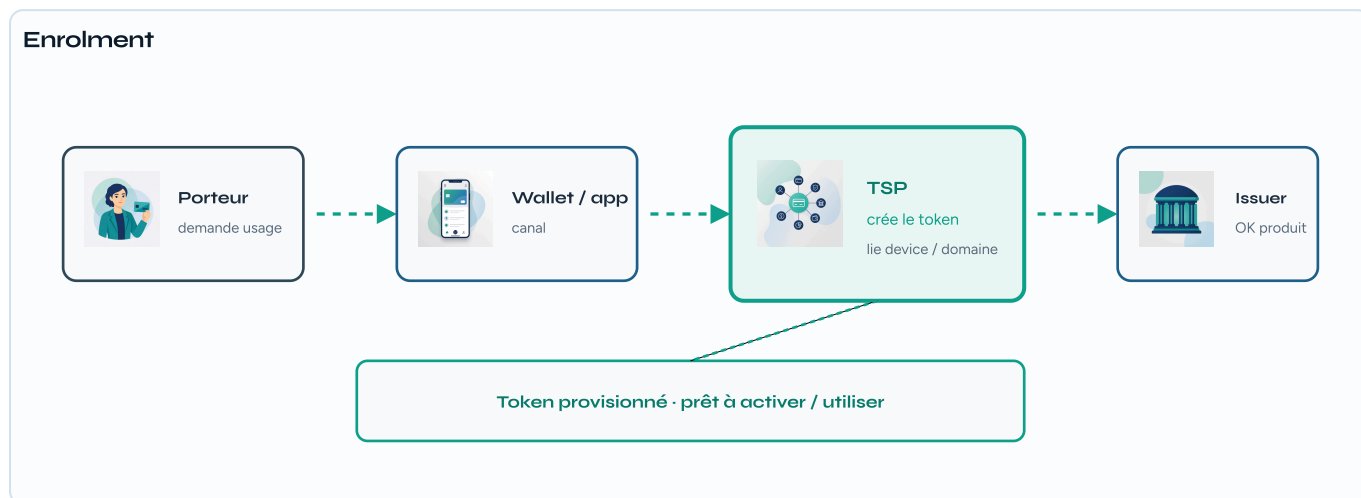


Longue durée tant qu'actif · crypto de chaque txn = éphémère · détail des actions = section Gouvernance plus bas.

PROVISIONING

Enrolment & provisioning

Demande d'usage → contrôles → création du token et rattachement au device / canal.



APRÈS PROVISIONING

Où est stocké le token

Deux niveaux : **vault** (lien) vs **credential** (là où on paie). Vocabulaire vault / TSP : [Définition](#) ; terrains : [Domaines](#).



USAGE · AUTH

Qui voit le token · qui voit le PAN

En **network tokenization**, c'est le **token** qui part en autorisation jusqu'à l'acquéreur — le PAN n'apparaît qu'au moment de la détokerisation (réseau / TSP), pour joindre l'issuer.

Chaîne Auth tokenisée



Jusqu'à l'acquéreur inclus → TOKEN (+ crypto) · Après TSP → PAN / compte pour décider

4 · Issuer = décision sur le compte

L'émetteur autorise sur le produit / compte lié au PAN d'origine.

Il peut aussi appliquer des règles liées au token (device, domaine, état actif).

OK / KO remonte la chaîne — le commerçant voit le résultat, pas le PAN.

Rail Auth → Clearing → Settlement inchangé dans sa logique (J1).

Nuance à dire en salle

Network tokenization

VTS · MDES · wallets OEM...

Token va jusqu'à l'acquéreur

Détokenisation au réseau / TSP

Acquéreur : TOKEN · pas PAN

Vault marchand / PSP seul

Token opaque côté commerçant

Le PSP peut détokeniser avant

et envoyer le PAN à l'acquéreur

Acquéreur : peut revoir du PAN

~~Vault marchand seul : le token va jusqu'au commerçant~~

Routing détaillé (qui acquiert · qui AuthZ) : 3.3 · Architecture SI.

GOUVERNANCE

Activer · Suspendre · Supprimer

Détail des états de la carte du cycle — actions fines sur un contexte, sans forcément toucher toute la carte.

Actions TSP



INTRO CRYPTO

Cryptogrammes dynamiques

Le token protège l'identifiant ; le cryptogramme protège l'usage dans le temps et le contexte.

Token + cryptogramme



Voler « un numéro » ne suffit plus à rejouer la même opération

Intro seulement — détail SE / HCE / TEE en Jour 4.

ANCRAGE

Cas pratiques

Cas 1 — Device perdu

- Suspendre le token
- Carte source intacte

Cas 2 — Nouveau device

- Nouveau provisioning
- Même PAN, nouveau contexte

Cas 3 – Chez l'acquéreur ?

- Network token → TOKEN en Auth
- Vault marchand seul → PAN possible

Cas 4 – Carte réémise

- Re-liaison / re-provision
- COF : mapping TSP peut survivre

CLARIFICATION

Ce que ce n'est pas

Lifecycle token ≠ cycle carte On peut suspendre un device sans résilier la carte.

Token ≠ cryptogramme Durable vs preuve dynamique (éphémère) d'une txn.

Vault ≠ credential d'usage Le vault détient le lien ; le device / marchand présente.

Acquéreur ≠ détenteur du PAN En network tokenization, l'acquéreur voit le token ; le PAN apparaît à la détokenisation réseau / TSP.

≠ Cours SE / HCE Secure Element, HCE, TEE = Jour 4.

Architecture SI tokenisation

DÉFINITION

Que montre l'architecture SI ?

Les briques qui **émettent**, **stockent** et **présentent** le token — puis qui **acquiert** le flux Auth et **route** jusqu'à l'AuthZ émetteur. Cycle de vie (états) : 3.2.

ÉLÉMENTS SI

Où tournent les briques

Briques tokenisation



Tokenisation réseau (VTS · MDES...)

Service scheme / TSP — le token va jusqu'à l'acquéreur · ≠ vault marchand seul

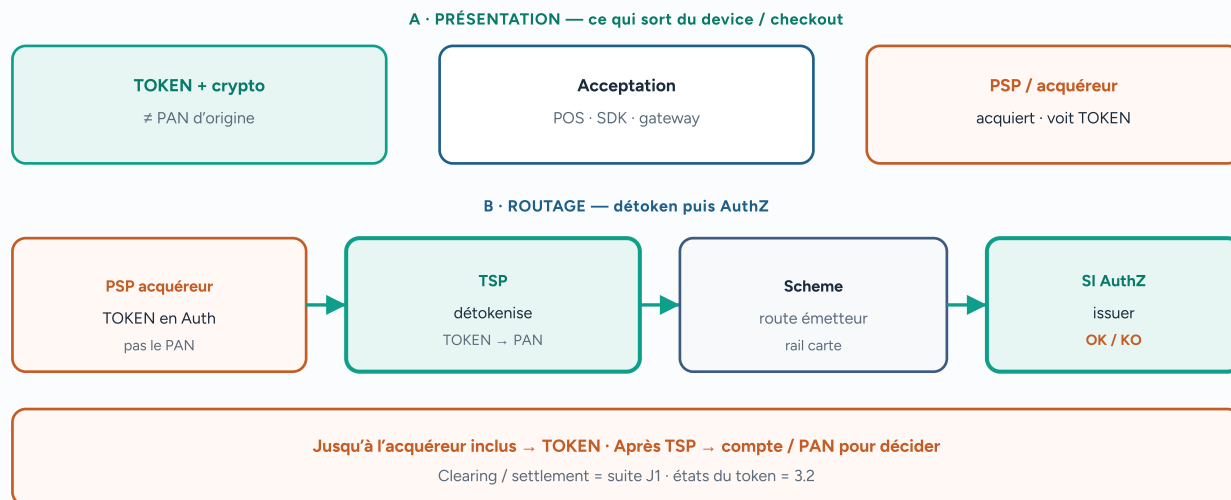
TSP = gouvernance token · Issuer = racine carte + décision AuthZ

ROUTAGE AUTH

Qui acquiert · comment ça route

Network tokenization : jusqu'à l'acquéreur inclus = **TOKEN** (+ crypto). Détokenisation au TSP / scheme → **AuthZ SI issuer**.

Flux Auth tokenisé



Vault marchand / PSP seul : le PSP peut détokeriser *avant* l'acquéreur — celui-ci peut alors revoir du PAN. Détail domaines : 3.1.

SYNTHÈSE

Qui voit quoi · qui AuthZ

ACTEUR	VOIT	RÔLE
App / wallet	TOKEN (+ crypto)	Présente le credential
Acceptation · PSP / acquéreur	TOKEN (network tok.)	Acquiète le flux Auth
TSP	Mapping TOKEN ↔ PAN	Gouverne · détokerise
Scheme	Rail / routage	Route vers l'émetteur
SI issuer	Compte / PAN + règles token	AuthZ OK / KO

TSP ≠ issuer : gouvernance du token d'un côté ; produit carte et décision AuthZ de l'autre. Network tokenization (VTS / MDES...) = service scheme / TSP.

CLARIFICATION

Ce que ce n'est pas

Token ≠ remplacement de l'émetteur Substitut d'identifiant — pas la décision de paiement.

≠ Architecture wallet complète SE / HCE / TEE et détail NFC = Jour 4.

Sécurité & conformité

DÉFINITION MONÉTIQUE

Que couvre ce bloc ?

Les mécanismes qui accompagnent la tokenisation : **device binding**, **SCA / DSP2**, **cryptogrammes**, impact **PCI-DSS** et **protection des données**. La tokenisation réduit l'exposition du PAN ; elle ne remplace ni authentification forte, ni gouvernance, ni audit.

Sécurité de l'identifiant ≠ sécurité de l'authentification.

VOCABULAIRE

Socle sécurité réutilisable

Trois leviers complémentaires — à ne pas fusionner.

Device binding · SCA · Cryptogrammes



Device binding

token ↔ device
contexte d'usage



SCA / DSP2

authentification forte
légitimité porteur



Cryptogrammes

preuve dynamique
anti-réutilisation

Trois couches — tokeniser n'équivaut pas à « être SCA »

PCI-DSS & protection des données

La tokenisation aide à réduire le scope — elle ne ferme pas le dossier conformité.

Exposition · Scope · Gouvernance



« Tokenisé ⇒ conforme » reste un raccourci — audit et gouvernance persistent

	AVANT TOKENISATION	APRÈS TOKENISATION
Chez le marchand	PAN stocké / transmis → scope PCI large	TOKEN (souvent) → scope potentiellement réduit
Ce qui reste	Vault / TSP, audit, gouvernance, SCA, responsabilités issuer	
Piège	« Tokenisé ⇒ conforme » — faux ; réduction à valider, pas à proclamer	

PCI-DSS

- Réduction d'exposition du PAN
- Allègement possible de périmètres
- Gouvernance ne disparaît pas

Protection des données

- SCA reste un sujet distinct
- Traçabilité et conservation
- Responsabilités TSP / issuer / wallet

RÔLE

Ce qu'on réduit, ce qu'on garde

Réduit Exposition du PAN, réutilisation triviale, certains risques côté marchand.

Conservé Fraude, gouvernance des tokens, compromission de device, erreurs d'intégration, exigences d'audit.

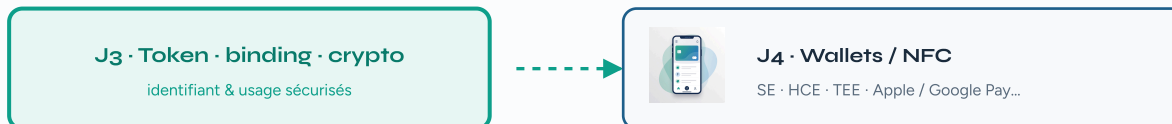
Déplacé Une part de responsabilité se concentre sur TSP, issuer, wallet et briques de confiance.

PONT J4

Pourquoi ce bloc précède wallets et NFC

Apple Pay, Google Pay, SE, HCE et TEE seront lisibles si l'on a déjà dissocié **carte source**, **token**, **cryptogramme** et **device**.

J3 → J4



ANCRAGE

Cas pratiques

Cas 1 — Scope PCI

- Qu'est-ce qui sort réellement du scope ?
- Qui porte vault et contrôles d'audit ?

Cas 2 — SCA vs token

- Token ≠ preuve d'identité forte
- Distinguer identifiant et authentification

CLARIFICATION

Ce que ce n'est pas

« **Tokenisé ⇒ conforme** » Raccourci dangereux. La tokenisation aide ; elle ne remplace pas le dispositif de conformité.

Token ≠ SCA Device binding et cryptogramme ne se substituent pas à l'authentification forte du porteur.

≠ Risque zéro device Compromission de device, mauvaise intégration et gouvernance restent des sujets SI.

Atelier

DÉFINITION MONÉTIQUE

Objectif de l'atelier

Partir d'un message d'autorisation classique (J1) et le transformer en scénario **tokenisé** : visualiser PAN vs token, jouer le lifecycle (provision → payer → suspendre → supprimer), et relier au **scope PCI**.

KIT

Visuel & logiciel

À apporter

- Carte plastique + captures wallet
- PAN masqué vs token / DAN
- Visuels support (Définition)

Logiciel

- Simulateur maison PAN ↔ token ↔ lifecycle
- Provision → payer → suspendre → supprimer

Prep

- Aucun achat matériel
- Pas VTS/MDES sauf accès banque
- Relier au scope PCI

DÉROULÉ

Atelier guidé

Quatre temps

ANCRAGE

Livrables par groupe

LIVRABLE	ATTENDU
Message Auth	Schéma J1 (PAN) → même flux tokenisé (TOKEN + crypto)
Lifecycle	Activer · Suspendre · Supprimer — cas device perdu
Scope PCI	Ce qui sort / ce qui reste (marchand · TSP · issuer)

À produire

- Schéma avant / après tokenisation
- Tableau PAN vs token vs gouvernance

Questions guide

- Qui voit encore le PAN ?
- Qui peut suspendre le token ?
- Qu'est-ce qui change dans l'auth ?

CLARIFICATION

Ce que l'atelier n'est pas

≠ Labo production Sandbox / simulateur uniquement — pas de données réelles.

≠ Cours J4 On prépare wallets / NFC — on ne les déroule pas ici.